

La sécurité de l'information

Stéphane Gill

Stephane.Gill@CollegeAhuntsic.qc.ca

Table des matières

Introduction.....	2
Quelques statistiques.....	3
Sécurité de l'information – Définition.....	4
Bref historique de la sécurité.....	5
La sécurité un processus et non un ensemble de produits.....	6
Inspection.....	6
Protection.....	7
Détection.....	7
Réaction.....	8
Réflexion.....	8
Les normes et les méthodes de sécurité.....	9
Qu'est-ce qu'une norme.....	9
Qu'est qu'une méthode.....	9
Méthode Mehari.....	10
Phase préparatoire.....	11
Phase opérationnelle d'analyse des risques.....	12
Phase de planification et de traitement des risques.....	13
Grille d'exposition naturelle.....	13
Tableau (ou grille) d'impact intrinsèque.....	14
Références.....	15

Document écrit par Stéphane Gill

© Copyright 2013 Stéphane Gill

Ce document est soumis à la licence GNU FDL. Permission vous est donnée de distribuer et/ou modifier des copies de ce document tant que cette note apparaît clairement.

Introduction

Les entreprises font aujourd'hui de plus en plus appel aux systèmes d'information pour optimiser leur fonctionnement et pour améliorer leur rentabilité. La sécurité informatique est donc devenue une problématique incontournable. Un accès non autorisé ou malveillant aux systèmes informatiques d'une entreprise peut induire en quelques minutes des pertes financières très importantes. Voici deux incidents qui illustrent bien le genre de perte financière importante engendrée par l'attaque de systèmes informatiques.

*« Le 8 février 2002, Amazon.com, Yahoo!, eBay ou E*Trade n'ont pu maîtriser le flux de données qui a inondé leurs serveurs pendant 90 minutes. Au plus fort de l'attaque le serveur de Yahoo recevait un flux de données ayant un débit de 1 Gbit/s.*

Le site d'enchères électroniques eBay a estimé le coût de l'attaque à 80 000 dollars US en investissements de sécurité. Selon le « Yankee Group », cabinet d'analystes spécialistes de l'économie Internet, l'heure d'arrêt d'activité d'Amazon.com lui aura coûté plus 240 000 dollars US. Toujours d'après le même cabinet d'analyse, l'attaque perpétrée sur les serveurs d'Amazon.com aura engendré au total plus de 1,2 milliard de dollars de pertes, réparties en manque à gagner et conséquences boursières. »

Référence : <http://www.01net.com> Jérôme Saiz « Internet : attention pirates ! »

« Le 7 février 2000, un certain nombre de sites Web parmi les plus connus (Yahoo, eBay, CNN, Amazon, MSN, Buy.com, etc.) ont été paralysés pendant plusieurs heures, victimes d'attaques par saturation. Ces attaques ont rendu les sites en partie ou complètement hors-service. Les victimes ont évalué les pertes dues aux attaques à 1,7 milliards de dollars. »

Référence : Muriel Drouineau « Mafiaboy avoue tout ! »

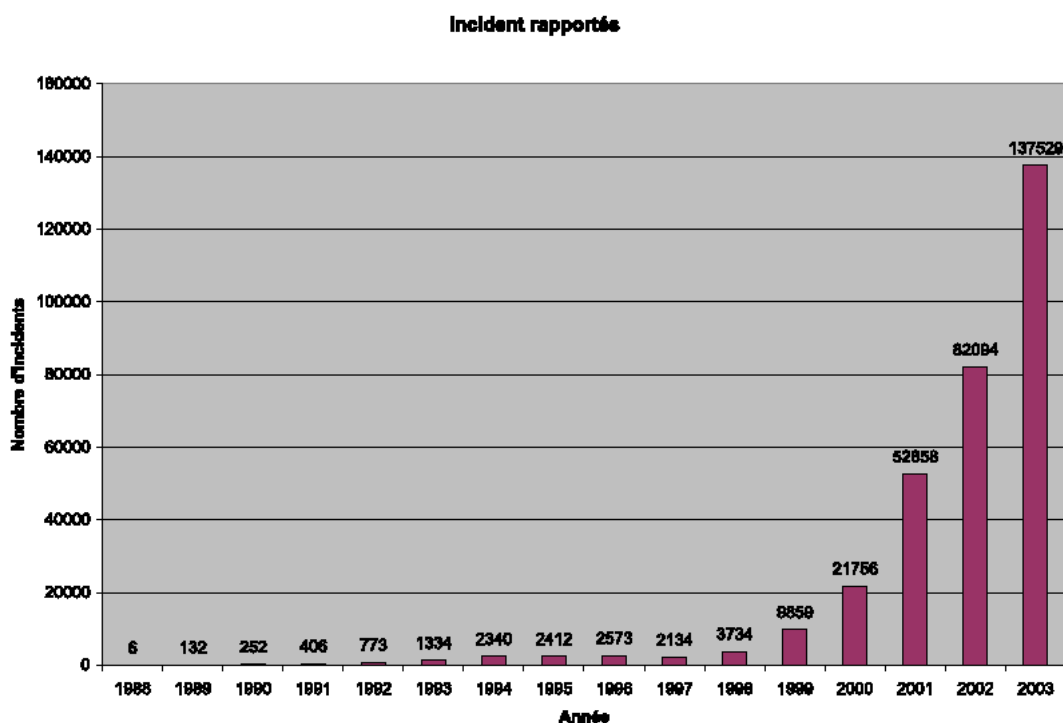
De nombreuses personnes se sont penchées et se penchent encore sur le problème de la sécurité informatique. Voici la réflexion de Donald L. Pipkin auteur du livre « Sécurité des systèmes d'information »

« Il n'existe pas de réponse simple aux problèmes de sécurité. Malheureusement, les gens sont trop souvent convaincus que les seules choses dont ils aient besoin pour assurer leur sécurité, c'est d'installer un firewall, d'améliorer leur méthode d'authentification ou de définir un règlement

de sécurité. En vérité, toutes ces mesures contribuent à l'amélioration de la sécurité, mais aucune d'entre elles n'est une solution complète. »

Quelques statistiques

« Depuis 1988 le nombre d'incidents de sécurité ne cesse d'augmenter »



Référence : « CERT Coordination Center », 2005, CERT/CC Statistics 1988-2005.

« Le montant total des pertes subies en 2004 par 269 entreprises à la suite d'un incident de sécurité informatique a atteint un total de 141,5 millions de dollars, ce qui fait une moyenne de 526 000 dollars par entreprise »

Référence : « 2004 CSI/FBI Computer Crime and security Survey » Computer Security Institute, 2004.

« Malgré le fait que peu d'entreprises partagent leurs données financières, il semble que les pertes financières suite à un incident informatique soient en baisse ».

Référence : « 2010/2011 CSI/FBI Computer Crime and security Survey » Computer Security Institute, 2011.

« 93 % des entreprises qui ont éprouvé un désastre et qui n'avaient pas de sauvegarde de leurs informations ont disparu. »

Référence : « Disaster Recovery », Interex 98 Conference, 12 mai 1998.

« Plusieurs enquêtes ont montré qu'environ la moitié des attaques perpétrées contre des systèmes informatiques provenaient de l'intérieur de l'entreprise concernée. »

Référence : « 2004 CSI/FBI Computer Crime and security Survey » Computer Security Institute, 2004.

« 67% des entreprises considèrent que les attaques les plus fréquentes proviennent des logiciels malveillants. »

Référence : « 2010/2011 CSI/FBI Computer Crime and security Survey » Computer Security Institute, 2011.

« La grande majorité des entreprises croient que les cyber-attaques provenant de l'interne ont peu d'incidence financière. »

Référence : « 2010/2011 CSI/FBI Computer Crime and security Survey » Computer Security Institute, 2011.

Sécurité de l'information – Définition

La sécurité de l'information est l'ensemble des mesures adoptées pour empêcher l'utilisation non autorisée, le mauvais usage, la modification ou le refus d'utilisation d'un ensemble de connaissances, de faits, de données ou de moyens. Le terme sécurité de l'information désigne donc les mesures préventives que nous mettons en place pour préserver nos informations et nos moyens.

Les trois critères de sensibilité de l'information, communément acceptés, sont :

- La **disponibilité** : garantir l'accès à l'information en tout temps;
- L'**exactitude** : Garantir que l'information est bien celle que l'on croit être;

- La **confidentialité** : assurer que seules les personnes autorisées aient accès à l'information.

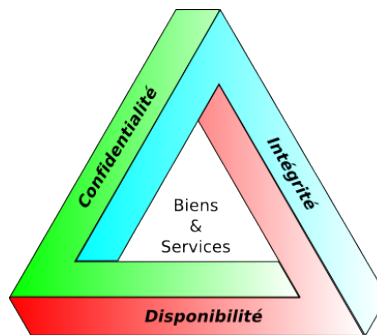


Figure 1: Représentation de la triade D, I, et C (source: wikipedia)

Bref historique de la sécurité

La façon dont nous avons géré la sécurité de l'information et les ressources des entreprises a évolué de pair avec notre société et nos technologies. Il est important de comprendre cette évolution pour savoir comment nous devons considérer la sécurité aujourd'hui.

- **La sécurité physique** : Pour éviter que l'on puisse s'emparer physiquement de l'information les messages étaient escortés par des soldats.
- **La sécurité des communications** : Jules César créa les messages codés.
- **La sécurité des transmissions** : Dans les années 1950, il a été démontré que l'accès aux messages pouvait être réalisé en analysant les signaux électriques d'une ligne téléphonique.
- **La sécurité de l'ordinateur** : Au début des années 1970, un modèle pour sécuriser les opérations des ordinateurs fut développé.
- **La sécurité des réseaux** : La mise en réseau des ordinateurs, à la fin des années 1980, soulève de nouveaux problèmes.
- **La sécurité de l'information** : Début des années 2000...

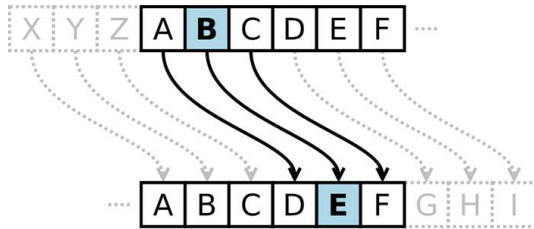


Figure 2: Chiffre de Jules César et machine Enigma

La sécurité un processus et non un ensemble de produits

La sécurité est un processus dont le but est de réduire les risques ou la probabilité de subir des dommages. Dans son livre « Sécurité des systèmes d'information », Donald L. Pepkin propose les cinq phases suivantes pour élaborer **un plan de sécurité** :

- **Inspection** : Identifier les fonctionnalités qui sont à la base des activités de l'entreprise. Évaluer les besoins en sécurité de l'organisation.
- **Protection** : Mettre en place des moyens pour une réduction dynamique des risques.
- **Détection** : Mettre en place des moyens pour une réduction réactive des risques.
- **Réaction** : Mettre en place un plan de secours d'urgence.
- **Réflexion** : Une fois l'incident terminé et tout remis en place, procéder à l'étude de l'événement.

Inspection

Les six étapes de l'inspection :

- Inventaire des ressources.

- Estimation de la menace.
- Analyse des pertes potentielles.
- Identification des vulnérabilités.
- Organisation de la protection.
- Évaluation de l'état actuel.

Protection

La protection est la phase où un ensemble de moyens sont mis en place afin de protéger les systèmes d'information. Voici quelques méthodes de protection :

- Le logiciel antivirus.
- Le contrôle d'accès (Authentification).
- Le pare-feu.
- L'établissement de procédure de sécurité.
- Le chiffrement des données.
- Les mécanismes de sécurité physique.
- Les sauvegardes.
- Les mécanismes de redondance de l'information.

Détection

La détection d'intrusion est fondée sur trois processus :

- **Analyse de signature** : Comparaison des données des journaux de bord avec un catalogue de signature d'attaques connues.
- **Analyse statique** : Analyse d'éléments d'état statiques. (Analyse des vulnérabilité et analyse de configuration).

- **Analyse dynamique** : Analyse de l'activité d'un système pour déterminer si une attaque est en cours (Analyse les traces enregistrées (history), analyse du trafic sur le réseau et analyse des événements dans les journaux de bord).

Réaction

Un plan de réponse aux incidents est un document qui décrit comment l'équipe gérant la sécurité de l'information doit réagir face à un incident de sécurité. Il existe 3 types de philosophie sous-jacente à un plan de réponse :

- **Surveiller et avertir** : surveillance constante, dès qu'un incident est détecté un responsable en est averti. Aucune autre action n'est lancée automatiquement.
- **Réparer et signaler** : tenter de remédier à l'incident le plus vite possible, signaler au responsable.
- **Poursuivre en justice** : Rassembler les preuves et alerter le plus vite possible le service juridique de l'entreprise.

Quelle que soit la philosophie retenue, un plan de réponse doit comporter les étapes de base suivante :

- Documentation
- Détermination
- Notification
- Appréciation
- Éradication
- Remise en état

Réflexion

Les 4 étapes d'une réflexion après un incident :

- Documentation de l'incident
- Évaluation de l'incident

- Relations publiques
- Suites judiciaires

Les normes et les méthodes de sécurité

Diverses normes aide à la mise en place d'un plan de sécurité de l'information efficace. Les plus courantes sont sans doute les normes ISO 27001 et 27002. Des méthodes formelles d'analyse des risques ont aussi été développé pour facilité l'application de certaines normes.

Qu'est-ce qu'une norme

Une norme est un document de référence contenant des spécifications techniques précises destiné à être utilisé comme règles ou lignes directrices. Certaines normes traitant de sécurité de l'information sont disponibles:

- ISO 13335 : Concepts et modèles pour la gestion de la sécurité des TIC (1996),
- ISO 15408 : Critères communs pour l'évaluation de la sécurité des Technologies de l'Information,
- ISO/CEI 27001 : Description des exigences pour la mise en place d'un Système de Management de la Sécurité de l'Information (SMSI).
- ISO/CEI 27002 : Code de bonnes pratiques pour la gestion de la sécurité d'information (anciennement la norme ISO/CEI 17799).
- ISO/CEI 27005 : Proposition d'une méthode d'appréciation des risques (cette phase est obligatoire dans le cadre d'une certification ISO/CEI 27001).
- ISO/CEI 27006 : Contient des informations sur le profile propre de l'auditeur 27001.

Qu'est qu'une méthode

Une méthode est un moyen d'arriver efficacement à un résultat souhaité. Une méthode n'est pas un document de référence. Il existe de nombreuses méthodes de sécurité de l'information :

- Mehari : *Méthode harmonisée d'analyse des risques*, développée par le CLUSIF;
- Ebios : *Expression des besoins et identification des objectifs de sécurité*, développée par l'Agence nationale de la sécurité des systèmes d'information (ANSSI);
- Cramm : *CCTA Risk Analysis and Management Method* créé en 1987 par *Central Computing et Telecommunications Agency (CCTA)*.
- OCTAVE : *Operationally Critical Threat, Asset, and Vulnerability Evaluation*, développée par l'Université de Carnegie Mellon.

Méthode Mehari

La méthode harmonisée d'analyse des risques (Mehari) est une méthode visant à la sécurisation informatique d'une entreprise ou d'un organisme. Cette méthode développée par le CLUSIF propose un ensemble d'outils capable d'accompagner les responsables des systèmes de l'information dans les différentes démarches impliquées dans la réduction des risques liés à l'information. La méthode est conforme à la norme ISO/IEC 27001 et répond aux recommandations de la norme ISO/IEC 27005. Les outils fournis permettent :

- d'analyser et classer les enjeux majeurs;
- d'étudier les vulnérabilités;
- de réduire la gravité des scénarios de risques;
- de piloter la sécurité de l'information.

La méthode Mehari comporte 3 phases:

- Phase préparatoire;
- Phase opérationnelle d'analyse des risques;
- Phase de planification du traitement des risques.

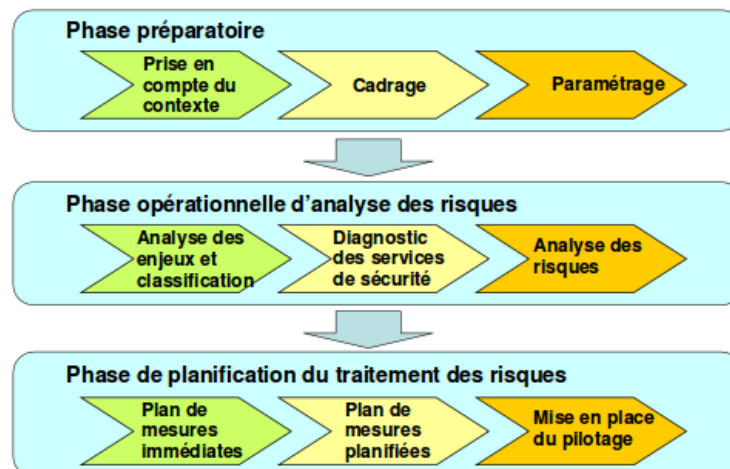


Figure 3: Méthode Mehari

La majorité du travail impliqué dans l'application de la méthode Mehari est réalisé par les gestionnaires de l'entreprise ou de l'organisation où le plan de sécurité est élaboré.

Phase préparatoire

La phase préparatoire comprend elle-même trois étapes, qu'il est préférable de mener successivement. Ces étapes sont:

- La prise en compte du contexte (Contexte stratégique; contexte technique; contexte organisationnel)
- Le cadrage de la mission d'analyse et de traitement des risques (Périmètre technique; périmètre organisationnel; structure de pilotage de la mission)
- La fixation des principaux paramètres de l'analyse des risques (Grille d'acceptabilité des risques; grilles des expositions naturelles; grille d'appréciation des risques)

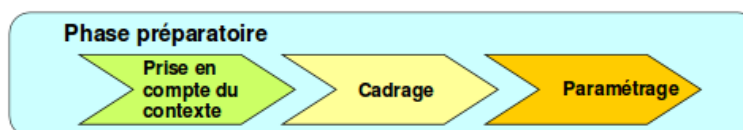


Figure 4: Phase préparatoire

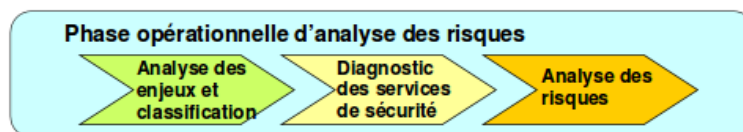
Certaines tâche de la phase préparatoire peuvent être réalisées en tout ou en partie par un technicien en informatique:

- Prise en compte du contexte technique.
 - L'architecture du système informatique;
 - L'architecture des réseaux;
 - L'architecture du système applicatif;
 - L'inventaire de l'équipement informatique;
 - L'inventaire des fournisseurs.
- Détermination de la grille des expositions naturelles.
- Détermination du tableau d'impact intrinsèque.

Phase opérationnelle d'analyse des risques

La phase d'analyse des risques comprend trois étapes principales. Ces étapes sont:

- L'analyse des enjeux et la classification des actifs (Échelle de valeur des dysfonctionnements, classification des actifs, tableau d'impact intrinsèque).
- Le diagnostic de la qualité des services de sécurité (Établissement du schéma d'audit; Diagnostic de la qualité des services de sécurité).
- L'appréciation des risques (Sélection des scénarios de risque; estimation des risques).



Un technicien en informatique peut avoir à participer à la réalisation des tâches suivantes:

- Compléter la grille des expositions naturelles.
- Compléter les tableaux d'impact intrinsèque.

Phase de planification et de traitement des risques

La phase de planification et de traitement des risques comprend trois étapes principales. Ces étapes sont:

- La planification des actions immédiates (Sélection des risques à traiter en priorité absolue; Choix des mesures à mettre en oeuvre immédiatement).
- La planification des mesures à décider dans le cadre courant (Stratégie de traitement et priorités; Choix des mesures et planification).
- La mise en place du pilotage du traitement des risques (Organisation du pilotage; Indicateurs et tableau de bord).

Un technicien en informatique participera à la mise en place des mesure de sécurité informatique.

Tableau d'exposition naturelle

Déterminer la probabilité d'occurrence de la menace, en dehors de toute mesure sécurité. Une menace consiste en une situation ou une condition avec le potentiel de compromettre la sécurité de l'information. La base de connaissance de Mehari 2010 contient des scénarios standard de menace. voici un exemple de tableau d'exposition naturelle.

Évaluation de l'exposition naturelle						
Évaluation de la probabilité des événements suivants		Très improbable	Plutôt improbable	Plutôt probable	Très probable	Status-Expo
Accidents						
AC01	Court-circuit au niveau du câblage ou d'un équipement.		X			2
AC02	Chute de la foudre		X			2
AC03	Incendie naissant dans les locaux : corbeille à papier, cendrier, etc.		X			2
AC04	Accidents dus à l'eau ou à des liquides (fuite d'une canalisation, liquides renversés accidentellement, etc.).		X			2
AC05	Inondation causée par une canalisation percée ou crevée		X			2
AC06	Inondation causée par la crue d'une rivière ou une remontée de la nappe phréatique		X			2
AC07	Inondation causée par l'extinction d'un incendie voisin.		X			2
AC08	Coupure d'énergie de longue durée pour une cause extérieure		X			2
AC09	Indisponibilité totale des locaux : Interdiction d'accès décidée par la préfecture		X			2

La première étape est de concevoir un tableau qui représente l'exposition naturelle de l'entreprise ou de l'organisation pour laquelle le plan de sécurité est développé. Par la suite, il faut déterminer le niveau d'exposition naturelle pour chacune des menaces. Voici la définition des niveaux d'exposition naturelle:

- **Niveau 1 – L'exposition est très faible:** Indépendamment de toute mesure de sécurité, la probabilité d'occurrence d'un tel scénario est extrêmement faible et pratiquement négligeable.
- **Niveau 2 – L'exposition est faible:** Même en l'absence de toute mesure de sécurité, l'environnement (culturel, humain, géographique, ...) et le contexte (stratégique, concurrentiel, social, ...) font que la probabilité d'occurrence d'un tel scénario, à court ou moyen terme est faible.
- **Niveau 3 – L'exposition est moyenne:** L'environnement et le contexte de l'entreprise font que, si rien n'est fait pour l'empêcher, un tel scénario devrait se produire, à plus ou moins court terme.
- **Niveau 4 – L'exposition est forte:** L'environnement ou le contexte font que si rien n'est fait, un tel scénario se réalisera sûrement, vraisemblablement à court terme.

Tableau (ou grille) d'impact intrinsèque

La grille d'impact intrinsèque, permet d'évaluer les conséquences (type de dommages subits) de l'occurrence d'une menace, indépendamment de toute mesure de sécurité. La première étape est de construire la grille puis de la remplir pour chacune des menaces potentielles.

Tableau d'Impact Intrinsèque				
Classification des données, informations et éléments d'infrastructure		D	I	C
Données et informations				
D01	Fichiers de données ou bases de données applicatives			
D02	Fichiers bureautiques partagés			
D03	Fichiers bureautiques personnels			
D04	Informations écrites ou imprimées détenues par les utilisateurs, archives personnelles			
D05	Listings ou états imprimés des applications informatiques			
D06	Messages échangés, écrans applicatifs (données partielles)			

Le remplissage de la grille s'effectue en transcrivant (par une valeur de 1 à 4) le niveau de conséquence d'une atteinte à la disponibilité, l'intégrité ou la confidentialité de chacun des types d'actifs. Voici la définition des niveaux:

Niveau 1 - Non significatif: Presque aucun impact sur le fonctionnement.

Niveau 2 – Important: Perturbe le fonctionnement de l'entité.

Niveau 3 - Très grave: Dysfonctionnement très grave sans que son avenir soit compromis.

Niveau 4 – Vital: Met en danger l'existence même de l'entité.

Exemple d'échelle de dysfonctionnement (source: Mehari 2010 – Guide de l'analyse des enjeux et de la classification):

1. Gestion financière et budgétaire

Dysfonctionnement	Niveau 1 Non significatif	Niveau 2 Important	Niveau 3 Très Grave	Niveau 4 Vital
<i>Perte financière</i>	Perte < 1 M€	Perte comprise entre 1 M€ et 10 M€	Perte comprise entre 10 et 100 M€	Perte > 100 M€
<i>Fraude ou détournement de fonds</i>	Fraude ou détournement dans la gestion des achats et des paiements correspondants ou dans la gestion des livraisons.			
<i>Incapacité à facturer les livraisons</i>	Incapacité globale à facturer durant moins de 1 semaine	Incapacité globale à facturer comprise entre 1 semaine et 1 mois Perte des informations sur les livraisons effectuées sur une journée	Incapacité globale à facturer durant plus de 1 mois Perte définitive des preuves des livraisons d'une semaine	
<i>Dysfonctionnement du processus de relance des clients</i>	Indisponibilité temporaire de l'outil de relance	Indisponibilité durable de l'outil de relance		

Références

Donald L. Pipkin, « Sécurité des systèmes d'information », CampusPress, 2000.

Eric Maiwald, « Sécurité des réseaux », Campus press, 2001.

Aron Hsiao, « Sécurité sous Linux », Campus press, 2001.

« Mehari 2010 – Guide de la démarche d'analyse et de traitement du risque », Clusif, 2011.

« Mehari 2010 – Guide de l'analyse et du traitement des risques », Clusif, 2010.